

File No.: EXP202307000

RESOLUTION OF SANCTIONING PROCEDURE

From the procedure instructed by the Spanish Agency for Data Protection and based on the following

FACTS

FIRST: A.A.A. (hereinafter, the complainant) filed a complaint with the Spanish Agency for Data Protection on April 11, 2023. The complaint is directed against KAFFA KOFFEE ORGANISATION, S.L. with NIF B06864029. The reasons for the complaint are as follows:

The complainant claims for the receipt of an email, dated 11/04/2023, sent to more than 400 recipients, including the complainant, without using the BCC functionality.

Along with the complaint, a copy of the received email and its headers is provided, with the subject: "Surprise your team with the best specialty coffee!". This is a message sent from the email address and marked as "high importance". The personal data revealed is the email address, most of which are composed of the first name and surname of the interested party.

Additionally, a copy of a subsequent opposition request and delivery receipt is attached.

SECOND: In accordance with Article 65.4 of Organic Law 3/2018, of December 5, on Personal Data Protection and Guarantee of Digital Rights (hereinafter LOPDGDD), the aforementioned complaint was forwarded to KAFFA KOFFEE ORGANISATION, S.L. for analysis and to inform this Agency within one month of the actions taken to comply with the requirements set forth in data protection regulations. The transfer, which was carried out in accordance with the rules established in Law 39/2015, of October 1, on the Common Administrative Procedure of Public Administrations (hereinafter, LPACAP), was attempted to be notified electronically, but it was marked as "expired" as it was not accessed by the responsible entity.

Although the notification was validly carried out electronically, considering the procedure completed in accordance with the provisions of Article 41.5 of the LPACAP, a new dispatch was made, which was duly notified on December 12, 2023. In this notification, the obligation to communicate electronically with the Administration was reminded, and information was provided on how to access such notifications, reiterating that, henceforth, notifications would be made exclusively by electronic means. No response has been received to this transfer letter.

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

THIRD: On July 11, 2023, in accordance with Article 65 of the LOPDGDD, the complaint filed by the complainant was admitted for processing.

FOURTH: According to the report obtained from the AXESOR tool, the entity KAFFA KOFFEE ORGANISATION, S.L. is a microenterprise established in 2021, with a turnover of (...) in 2022.

FIFTH: On June 10, 2024, the Director of the Spanish Agency for Data Protection decided to initiate sanctioning proceedings against the respondent for the alleged infringement of Articles 5.1.f) and 32 of Regulation (EU) 2016/679 (General Data Protection Regulation, hereinafter GDPR), classified under Articles 83.5 and 83.4 of the GDPR, respectively.

SIXTH: The aforementioned initiation agreement was notified in accordance with the rules established in the LPACAP on June 11, 2024, and after the period granted for the submission of allegations had elapsed, it was confirmed that no allegations had been received from the respondent.

Article 64.2.f) of the LPACAP -provision of which the respondent was informed in the initiation agreement- establishes that if no allegations are made within the stipulated period regarding the content of the initiation agreement, when it contains a precise statement regarding the attributed responsibility, it may be considered a proposal for resolution. In this case, the initiation agreement of the sanctioning file determined the facts on which the accusation was based, the infringement of the

GDPR attributed to the respondent, and the sanction that could be imposed. Therefore, considering that the respondent has not made any allegations regarding the initiation agreement of the file and in accordance with the provisions of Article 64.2.f) of the LPACAP, the aforementioned initiation agreement is considered in this case as a proposal for resolution.

In light of all the actions taken by the Spanish Agency for Data Protection in this procedure, the following facts are considered proven,

PROVEN FACTS

FIRST: KAFFA KOFFEE ORGANISATION, S.L. sends an email, marked as "high importance," to more than 400 recipients, including the complainant, without using the BCC functionality.

SECOND: The complainant presents a copy of the received email where the email addresses of the other recipients are visible. They also present a copy of the response to the email where they request to be unsubscribed and state that they have never subscribed to that list nor given their consent to receive messages from the respondent.

THIRD: The personal data revealed is the email address of the affected individuals, most of which are composed of the first name and surname, and

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

3/11

thus exposing it to the other recipients of this email.

FOURTH: KAFFA KOFFEE ORGANISATION, S.L. has not responded to the request for information sent by this Agency via electronic means on 29/05/2023 and reiterated by postal mail on 09/06/2023, having been duly notified on 12/12/2023. No allegations have been presented regarding the initiation agreement of the sanctioning procedure.

LEGAL GROUNDS

I

Competence

In accordance with the powers granted to each supervisory authority by Article 58.2 of the GDPR, and as established in Articles 47, 48.1, 64.2, and 68.1 of the LOPDGDD, the Director of the Spanish Data Protection Agency is competent to initiate and resolve this procedure.

Furthermore, Article 63.2 of the LOPDGDD states: "The procedures processed by the Spanish Data Protection Agency shall be governed by the provisions of Regulation (EU) 2016/679, this organic law, the regulatory provisions issued for its development, and, in so far as they do not contradict them, subsidiarily by the general rules on administrative procedures."

II

Preliminary Issues

In this case, there is evidence of the processing of personal data by KAFFA KOFFEE ORGANISATION, S.L. in its business activity, as established in Article 4.2 of the GDPR, consisting of using the email addresses of more than 400 recipients to send a commercial communication advertising its products:

"processing": any operation or set of operations performed on personal data or sets of personal data, whether by automated means or not, such as collection, recording, organization, structuring, storage, adaptation or modification, extraction, consultation, use, communication by transmission, dissemination, or any other form of enabling access, comparison or interconnection, limitation, erasure, or destruction;

KAFFA KOFFEE ORGANISATION, S.L. carries out this activity in its capacity as the data controller, as it is the entity that determines the purposes and means of such activity, by virtue of Article 4.7 of the GDPR:

"data controller" or "controller": the natural or legal person, public authority, service, or other body that, alone or jointly with others, determines the purposes and means of the processing; if the law of the Union or of the Member States determines the purposes and means of the processing, the controller

or the specific criteria for its appointment may be established by the law of the Union or of the Member States.

III

Obligation Breached

The known facts constitute an infringement attributable to KAFFA KOFFEE ORGANISATION, S.L. for non-compliance with the provisions of Articles 5.1.f) and 32 of the GDPR.

IV

Article 5.1.f) of the GDPR

Article 5.1.f) "Principles relating to processing" of the GDPR states:

"1. Personal data shall be:

f) processed in a manner that ensures appropriate security of the personal data, including protection against unauthorized or unlawful processing and against accidental loss, destruction, or damage, by means of appropriate technical or organizational measures ('integrity and confidentiality')."

This principle assigns to KAFFA KOFFEE ORGANISATION, S.L., as the data controller, the obligation to prevent unauthorized or unlawful processing of this data, as well as its loss or destruction.

Therefore, it should not process personal data if it is not in a position to guarantee the confidentiality and integrity of such data and prevent a third party from accessing data that does not concern them, as well as to avoid its loss or destruction.

The data controller is obliged to process personal data in such a way as to ensure its confidentiality by applying appropriate technical and organizational measures. For a breach of Article 5.1.f) of the GDPR to occur, there must have been a loss of confidentiality or integrity.

In this case, from the documentation in the file, there is evidence of a breach by KAFFA KOFFEE ORGANISATION, S.L. of the provisions of Article 5.1.f) of the GDPR, as there has been a lack of confidentiality in the processing of personal data, resulting from sending an email with the recipients' addresses visible to all of them. The principle of confidentiality aims to prevent unauthorized leaks of personal data not consented to by the data subjects.

Therefore, in accordance with the evidence available at this moment in the resolution of the sanctioning procedure, it is considered that the known facts constitute an infringement attributable to KAFFA KOFFEE ORGANISATION, S.L. for violation of Article 5.1.f) of the GDPR.

V

Classification and Qualification of the Infringement of Article 5.1.f) of the GDPR

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

5/11

The violation of Article 5.1.f) of the GDPR constitutes the commission of the infringement defined in Article 83.5 of the GDPR, which under the heading "General conditions for the imposition of administrative fines" states:

"Violations of the following provisions shall be sanctioned, in accordance with paragraph 2, with administrative fines of up to 20,000,000 EUR or, in the case of an enterprise, an amount equivalent to a maximum of 4% of the total global annual turnover of the previous financial year, opting for the higher amount:

a) the basic principles for processing, including the conditions for consent under Articles 5, 6, 7, and 9."

In this regard, the LOPDGDD, in its Article 71 "Infringements," establishes that:

"Acts and behaviors referred to in paragraphs 4, 5, and 6 of Article 83 of Regulation (EU) 2016/679, as well as those that are contrary to this organic law, constitute infringements."

For the purposes of the statute of limitations, Article 72 "Infringements considered very serious" of the LOPDGDD indicates:

"1. Based on what is established in Article 83.5 of Regulation (EU) 2016/679, the following infringements are considered very serious and shall be subject to a three-year statute of limitations, which involve a substantial violation of the articles mentioned therein and, in particular, the following:

a) The processing of personal data in violation of the principles and guarantees established in Article 5 of Regulation (EU) 2016/679. (...)"

VI

Article 32 of the GDPR

Article 32 "Security of processing" of the GDPR establishes:

"1. Taking into account the state of the art, the costs of implementation, and the nature, scope, context, and purposes of the processing, as well as the risks of varying probability and severity for the rights and freedoms of natural persons, the controller and the processor shall implement appropriate technical and organizational measures to ensure a level of security appropriate to the risk, which may include, among others:

- a) the pseudonymization and encryption of personal data;
- b) the ability to ensure the confidentiality, integrity, availability, and permanent resilience of processing systems and services;
- c) the ability to restore the availability and access to personal data quickly in the event of a physical or technical incident;
- d) a process for regularly verifying, assessing, and evaluating the effectiveness of the technical and organizational measures to ensure the security of processing.

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

6/11

2. When assessing the adequacy of the security level, particular consideration shall be given to the risks presented by the processing of data, especially as a consequence of the accidental or unlawful destruction, loss, or alteration of personal data transmitted, stored, or otherwise processed, or the unauthorized communication or access to such data.

3. Adherence to a code of conduct approved pursuant to Article 40 or to a certification mechanism approved pursuant to Article 42 may serve as an element to demonstrate compliance with the requirements set out in paragraph 1 of this article.

4. The data controller and the data processor shall take measures to ensure that any person acting under the authority of the controller or the processor and having access to personal data may only process such data in accordance with the instructions of the controller, unless required to do so by Union or Member State law.

It should be noted that the GDPR in the aforementioned provision does not establish a list of security measures applicable according to the data being processed, but rather states that the controller and the processor shall implement appropriate technical and organizational measures to ensure a level of security that is adequate to the risk posed by the processing, taking into account the state of the art, the costs of implementation, the nature, scope, context, and purposes of the processing, as well as the risks of likelihood and severity for the rights and freedoms of the data subjects.

Furthermore, the security measures must be adequate and proportionate to the identified risk, indicating that the determination of technical and organizational measures must be made considering: pseudonymization and encryption, the ability to ensure confidentiality, integrity, availability, and resilience, the ability to restore availability and access to data after an incident, verification processes (not audits), evaluation, and assessment of the effectiveness of the measures. In any case, when assessing the adequacy of the security level, particular consideration shall be given to the risks presented by the processing of data, as a consequence of the accidental or unlawful destruction, loss, or alteration of personal data transmitted, stored, or otherwise processed, or the unauthorized communication or access to such data that could cause physical, material, or immaterial harm.

In the case at hand, KAFFA KOFFEE ORGANISATION, S.L did not use the procedure for sending emails when addressed to multiple recipients, which consists of using the option provided by the email application through the field known as "blind carbon copy" (BCC), allowing each recipient to see the rest of the sending addresses; and therefore, violating the current regulations on data protection. Consequently, KAFFA KOFFEE ORGANISATION, S.L did not have adequate measures in place to

ensure the confidentiality, integrity, and availability of the systems and services of the processing.

C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid
sedeagpd.gob.es

7/11

Therefore, and in accordance with the evidence available at this moment of resolution of the sanctioning procedure, it is considered that the known facts constitute an infringement attributable to KAFFA KOFFEE ORGANISATION, S.L, for violation of Article 32 of the GDPR.

VII

Classification and qualification of the infringement of Article 32 of the GDPR

The violation of Article 32 of the GDPR is classified in Article 83.4.a) of the aforementioned GDPR in the following terms:

“4. Infringements of the following provisions shall be sanctioned, in accordance with paragraph 2, with administrative fines of up to 10,000,000 EUR or, in the case of an enterprise, an amount equivalent to 2% of the total annual global turnover of the previous financial year, opting for the higher amount:
a) the obligations of the controller and the processor under Articles 8, 11, 25 to 39, 42, and 43.”

In this regard, the LOPDGDD, in its Article 71 “Infringements” establishes that “Acts and behaviors referred to in paragraphs 4, 5, and 6 of Article 83 of Regulation (EU) 2016/679, as well as those that are contrary to this organic law, constitute infringements.”

For the purposes of the limitation period, Article 73 “Infringements considered serious” of the LOPDGDD indicates:

“According to what is established in Article 83.4 of Regulation (EU) 2016/679, the following are considered serious and shall be subject to a limitation period of two years:

f) The failure to adopt those technical and organizational measures that are appropriate to ensure a level of security adequate to the risk of processing, as required by Article 32.1 of Regulation (EU) 2016/679.” (...)

VIII

Sanction for the infringements of Articles 5.1.f) and 32 of the GDPR

In order to determine the administrative fine to be imposed, the provisions of Articles 83.1 and 83.2 of the GDPR must be observed, which state:

“1. Each supervisory authority shall ensure that the imposition of administrative fines under this article for the infringements of this Regulation indicated in paragraphs 4, 5, and 6 is effective, proportionate, and dissuasive in each individual case.”

C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid
sedeagpd.gob.es

8/11

2. Administrative fines shall be imposed, depending on the circumstances of each individual case, as an additional or substitute measure for those contemplated in Article 58, paragraph 2, letters a) to h) and j). In deciding the imposition of an administrative fine and its amount in each individual case, the following shall be duly taken into account:

- a) the nature, severity, and duration of the infringement, taking into account the nature, scope, or purpose of the processing operation in question, as well as the number of affected parties and the level of damages they have suffered;
- b) the intentionality or negligence in the infringement;
- c) any measures taken by the data controller or processor to mitigate the damages suffered by the affected parties;
- d) the degree of responsibility of the data controller or processor, taking into account the technical or organizational measures they have implemented under Articles 25 and 32;
- e) any previous infringement committed by the data controller or processor;

- f) the degree of cooperation with the supervisory authority in order to remedy the infringement and mitigate the possible adverse effects of the infringement;
- g) the categories of personal data affected by the infringement;
- h) the manner in which the supervisory authority became aware of the infringement, particularly whether the data controller or processor notified the infringement and, if so, to what extent;
- i) when the measures indicated in Article 58, paragraph 2, have been previously ordered against the data controller or processor in relation to the same matter, compliance with such measures;
- j) adherence to codes of conduct under Article 40 or to certification mechanisms approved under Article 42;
- k) any other aggravating or mitigating factor applicable to the circumstances of the case, such as financial benefits obtained or losses avoided, directly or indirectly, through the infringement.”

For its part, Article 76 “Sanctions and corrective measures” of the LOPDGDD states:

“1. The sanctions provided for in paragraphs 4, 5, and 6 of Article 83 of Regulation (EU) 2016/679 shall be applied taking into account the criteria for graduation established in paragraph 2 of the aforementioned article.

2. In accordance with the provisions of Article 83.2.k) of Regulation (EU) 2016/679, the following may also be taken into account:

- a) The continued nature of the infringement.
- b) The connection of the infringer's activity with the processing of personal data.
- c) The benefits obtained as a result of the commission of the infringement.
- d) The possibility that the conduct of the affected party may have induced the commission of the infringement.
- e) The existence of a merger by absorption after the commission of the infringement, which cannot be attributed to the absorbing entity.
- f) The impact on the rights of minors.
- g) Having, when not mandatory, a data protection officer.
- h) The voluntary submission by the data controller or processor to alternative dispute resolution mechanisms, in cases where there are disputes between them and any affected party.”

In this case, in light of the infringement of Articles 5.1 f) and 32 of the GDPR, the imposition of a fine is warranted, in addition to the adoption of measures, if applicable. The fine imposed must be, in each individual case, effective, proportionate, and dissuasive, in accordance with the provisions of Article 83.1 of the GDPR.

According to the indicated provisions, in accordance with the evidence available at this moment of the resolution of the procedure, for the purpose of determining the amount of the sanctions to be imposed in this case, it is considered appropriate to graduate the sanctions according to the following criteria established by the transcribed provisions:

The following circumstances are considered for the graduation of the fine:

- Art. 5.1.f)

Article 83.2.a) of the GDPR: It is considered that the nature of the infringement is serious since it has resulted in an irreparable loss of disposition and control over personal data for the affected parties and due to the number of affected parties, which is estimated to be more than 400 email recipients.

- Art. 32 GDPR:

Art. 83.2.b GDPR: due to negligence in the infringement, given that every data controller must be aware of their duty to implement adequate technical and organizational measures to protect the security and confidentiality of the personal data they process.

Considering the factors presented, the assessed fine for the infringement of Article 5.1.f) of the GDPR is €1,500 (ONE THOUSAND FIVE HUNDRED euros) and for the infringement of Article 32 of the GDPR is €500 (FIVE HUNDRED euros).

The total amounts to €2,000 (TWO THOUSAND euros).

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

Imposition of Measures

It is agreed to impose on the responsible party the adoption of appropriate measures to adjust their actions to the regulations mentioned in this act, in accordance with the provisions of the aforementioned article 58.2 d) of the GDPR, according to which each supervisory authority may “order the controller or processor to ensure that the processing operations comply with the provisions of this Regulation, where appropriate, in a specific manner and within a specified period...”. The imposition of this measure is compatible with the sanction consisting of an administrative fine, as provided for in art. 83.2 of the GDPR.

In this case, the measure consists of ordering the respondent to adopt and demonstrate that they have adopted the appropriate technical and organizational measures to prevent the sending of emails to multiple recipients in which all their email addresses are displayed, within one month from the date this resolution becomes final and enforceable.

It is warned that failure to comply with the possible order to adopt the imposed measure may be considered an administrative infringement in accordance with the provisions of the GDPR, classified as an infringement in its articles 83.5 and 83.6, which may lead to the initiation of further administrative sanctioning proceedings.

Therefore, in accordance with the applicable legislation and having assessed the criteria for the graduation of sanctions whose existence has been established, the Director of the Spanish Agency for Data Protection RESOLVES:

FIRST: TO IMPOSE on KAFFA KOFFEE ORGANISATION, S.L., with NIF B06864029, a fine of €1,500 (ONE THOUSAND FIVE HUNDRED euros) for an infringement of article 5.1.f) of the GDPR, and a fine of €500 (FIVE HUNDRED euros) for the infringement of article 32 of the GDPR. The total amount is €2,000 (TWO THOUSAND euros).

SECOND: TO ORDER KAFFA KOFFEE ORGANISATION, S.L., with NIF B06864029, that pursuant to article 58.2.d) of the GDPR, within one month from the date this resolution becomes final and enforceable, to adopt and demonstrate that they have adopted the appropriate technical and organizational measures to prevent the sending of emails to multiple recipients in which all their email addresses are displayed.

THIRD: TO NOTIFY this resolution to KAFFA KOFFEE ORGANISATION, S.L.

FOURTH: This resolution will be enforceable once the period for filing the optional appeal for reconsideration (one month from the day following the notification of this resolution) has expired without the interested party having exercised this right.

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

The sanctioned party is warned that they must comply with the imposed sanction once this resolution becomes executive, in accordance with the provisions of Article 98.1.b) of the LPACAP, within the voluntary payment period established in Article 68 of the General Collection Regulation, approved by Royal Decree 939/2005, of July 29, in relation to Article 62 of Law 58/2003, of December 17, by making the payment, indicating the NIF of the sanctioned party and the procedure number that appears in the heading of this document, into the restricted account No. IBAN:

ES00-0000-0000-0000-0000-0000 (BIC/SWIFT Code: CAIXESBBXXX), opened in the name of the Spanish Agency for Data Protection at the banking entity CAIXABANK, S.A.

Otherwise, collection will proceed during the executive period.

Upon receiving the notification and once it is executive, if the date of executiveness falls between the 1st and the 15th of each month, inclusive, the deadline for making the voluntary payment will be until the 20th of the following month or the next business day thereafter, and if it falls between the 16th and the last day of each month, inclusive, the payment deadline will be until the 5th of the second following month or the next business day thereafter.

In accordance with the provisions of Article 50 of the LOPDGDD, this Resolution will be made public once it has been notified to the interested parties.

Against this resolution, which concludes the administrative procedure in accordance with Article 48.6 of the LOPDGDD, and in accordance with the provisions of Article 123 of the LPACAP, the interested parties may optionally file a motion for reconsideration before the Director of the Spanish Agency for Data Protection within one month from the day following the notification of this resolution or directly file a contentious-administrative appeal before the Contentious-Administrative Chamber of the National Court, in accordance with the provisions of Article 25 and paragraph 5 of the fourth additional provision of Law 29/1998, of July 13, regulating the Contentious-Administrative Jurisdiction, within two months from the day following the notification of this act, as provided in Article 46.1 of the aforementioned Law. Finally, it is noted that in accordance with the provisions of Article 90.3 a) of the LPACAP, the firm resolution in the administrative procedure may be provisionally suspended if the interested party expresses their intention to file a contentious-administrative appeal. If this is the case, the interested party must formally communicate this fact by means of a written document addressed to the Spanish Agency for Data Protection, submitting it through the Electronic Registry of the Agency [<https://sedeagpd.gob.es/sede-electronica-web/>], or through any of the other registries provided for in Article 16.4 of the aforementioned Law 39/2015, of October 1. They must also provide the Agency with documentation that proves the effective filing of the contentious-administrative appeal. If the Agency is not aware of the filing of the contentious-administrative appeal within two months from the day following the notification of this resolution, it will consider the provisional suspension to be concluded.

938-16012024

Mar España Martí

Director of the Spanish Agency for Data Protection

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es